SECURITY

SOC 2 & PCI-DSS Visual Guide

Trust criteria and card-data rules — turn audits from fire drills into routine.

ANIMATED WALKTHROUGH

Step through pages to play the animation

STEP 1/6

SOC 2: Trust Services Criteria

Five lenses auditors use to judge your controls.

Security

the baseline — required

Availability

uptime commitments

Processing Integrity

correct processing

Confidentiality

protect secrets

Privacy

personal info handling

Type I = controls designed well at a point in time. Type II = operating effectively over 6–12 months. Customers want Type II.

STEP 2/6

PCI-DSS: Requirements Map

Twelve requirements in four groups — all about card data.

1–2: Network
firewalls, no defaults

3–4: Protect data
encrypt stored + transit

7–9: Access control
least privilege, physical

10–12: Monitor + policy
logging, testing, program

Scope rule: shrink the cardholder data environment (CDE) — network segmentation means fewer systems in audit scope.

STEP 3/6

Evidence Collection

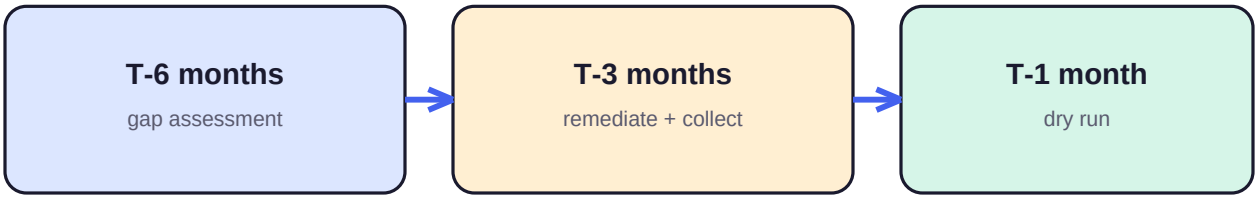
Auditors believe artifacts, not assertions.

- Map each control to evidence: screenshots, configs, logs, tickets, attestations.
- Collect continuously — a control with 11 months of evidence and a gap in month 6 fails.
- Automate: pull configs and access reviews from APIs into your evidence locker.
- Name and date everything; an auditor should never ask 'what is this?'.

STEP 4/6

Audit Prep Timeline

Start months before the auditor arrives.



Readiness assessments find the gaps cheaply. Walking into a Type II audit cold is how you buy a qualified opinion.

STEP 5/6

Shared Responsibility

Cloud doesn't outsource compliance.

Provider

physical, hypervisor, managed-service controls (their SOC 2 helps you).

You

data, access, configs, apps — always your responsibility.

Collect your providers' attestations as YOUR evidence — but the auditor still holds you accountable for what's in your account.

STEP 6/6

Controls That Serve Two Masters

One control set, multiple audits.

- Map once: a single access-review process evidences SOC 2 CC6.1 AND PCI Req 7.
- Common control framework (CCM/ISO 27001) as the spine; each audit reads off it.
- Avoid audit-specific theater — real controls pass every framework.
- Continuous compliance: monitor controls year-round, not audit-season.

STEP ✓/✓

Key Takeaways

SOC 2 & PCI-DSS — Remember

- SOC 2 judges five trust criteria; Type II (operating over time) is what customers want.
- PCI-DSS's 12 requirements protect card data — shrink the CDE to shrink scope.
- Evidence wins audits: collect continuously, automate pulls, label everything.
- Prep timeline: gap assessment at T-6mo, remediate at T-3, dry run at T-1.
- Cloud is shared responsibility — provider attestations are your evidence, not your excuse.
- One control framework mapped to many audits beats per-audit theater.

Keep exploring

Pair this guide with the matching video walkthroughs and hands-on labs at interstitiumlabs.dev